Multi-Agent AI for Smart Contract Audit and Cybersecurity Risk Assessment

Investigate smart contract risks through reproducible checks, independent model reviews and source-linked evidence.

THE CONTEXT

Code governs the asset

Smart contracts encode permissions, transfers and interactions in digital asset workflows. A defect in those controls can affect custody, transaction integrity or availability.

THE REVIEW PROBLEM

A finding needs evidence

A recognizable pattern may be benign in context. Model explanations may disagree. Reviewers need the relevant source, the reasoning behind each claim and a record of differences.

THE PLATFORM RESPONSE

Make findings inspectable

Combine an independent static baseline with three model reviews. Validate cited source evidence, reconcile compatible findings and preserve the original contributions for review.

CONNECT TECHNICAL FINDINGS TO DIGITAL ASSET EXPOSURE

Review question	Potential exposure	Evidence to inspect
Who can change or move value?	Unauthorized actions or asset transfers	Caller checks, state changes and recipients
What happens across a contract call?	Repeated withdrawals or inconsistent state	Call order, state updates and return values
Which assumptions drive outcomes?	Manipulated payouts or unavailable functions	Inputs, timing, randomness and iteration

One workspace. Two analysis modes.

Prepare a single Solidity file, investigate candidate findings and export a source-linked report.

STATIC ANALYSIS

Run checks on-device

15 pattern rules inspect the submitted source in the browser. No API key or backend is required.

The source stays on-device in this mode. Results provide a reproducible baseline with matched lines and recommended review actions.

API ANALYSIS

Compare independent reviews

Three parallel model reviews, using one Bedrock key: GPT-6.1 Sol, Claude Opus 5.5 and Grok 4.7.

Each model independently reviews the same source. The application validates evidence and reconciles compatible findings.

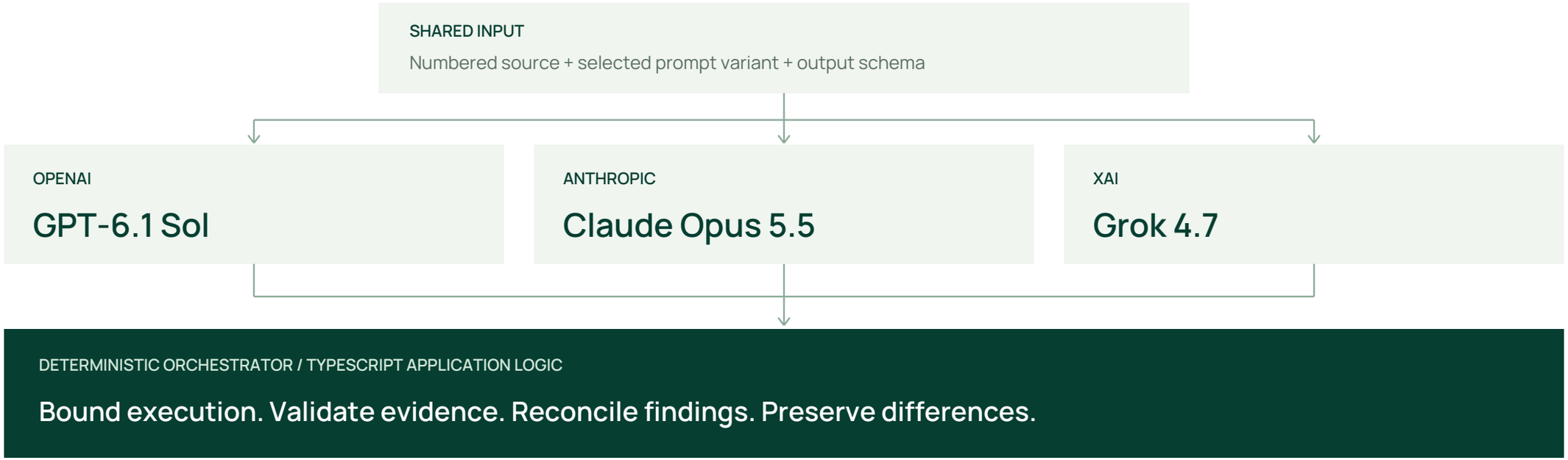
FROM SOURCE TO REVIEWABLE RESULTS

Task	Workspace interaction	Review output
Prepare	Upload .sol, edit source or choose a reference case	A numbered source snapshot; focus view for inspection
Investigate	Search; filter severity or model agreement; expand findings	Rationale, source excerpt, model contributions and action
Document	Jump to cited lines; open report details; download results	Source provenance and JSON or Markdown exports

The hosted website supports the complete browser workflow. The same workspace can also run locally from the repository.

Independent reviews. Explicit orchestration.

Three independent model tasks share bounded execution and one deterministic reconciliation process.



01 Supervise

Enforce attempt and time limits. Retry eligible temporary failures once, retaining completed peer reviews.

02 Validate & reconcile

Accept exact source evidence, then match compatible weaknesses. Keep ambiguous claims separate.

03 Preserve

Retain individual model outcomes and original findings so reviewers can inspect each contribution.

Static findings and peer answers are excluded from model prompts. Orchestration uses application logic, with no fourth model.

Evidence validation and model agreement

Inspect what was checked, how many models support a claim and how its proposed severity was selected.

SOURCE EVIDENCE ACCEPTANCE

01 Validate the response structure

Required fields, allowed severity labels and content limits must satisfy the review schema.

02 Bind the evidence to the source

The stated line range must be valid. The excerpt must reproduce those original source lines exactly, with at most 12 lines per finding.

03 Record the server's validation

The server records source validation only after these checks pass. A model cannot certify its own evidence as verified.

AGREEMENT-BASED CONFIDENCE

1 / 3	2 / 3	3 / 3
LOW	MEDIUM	HIGH

Each distinct supporting model counts once. Duplicate findings add no votes. Static matches and missing model results add no votes; the denominator remains three.

SEVERITY & DIFFERENCES

The highest proposed severity is displayed. Severity differences and incomplete model support identify findings to compare. Missing findings are not explicit rebuttals; original contributions remain available.

A HIGH-severity finding may have LOW agreement (1 / 3 models).

Severity expresses proposed impact; agreement expresses breadth of model support. Both remain available for review.

Source matching does not prove exploitability. Agreement is not a calibrated probability of correctness.

Connect risk findings to an audit trail.

Review recognizable source patterns, then retain the evidence and model context behind each result.

REPRESENTATIVE STATIC RISK FAMILIES

Access control & custody

tx.origin authorization, ownership changes and asset-transfer patterns.

External interactions

Calls before balance updates, unchecked call/send results and caller-controlled callbacks.

Execution authority

delegatecall and selfdestruct expressions, with their target and authorization assumptions.

Economic & time assumptions

Block-data randomness, predictable game outcomes and timestamp-sensitive logic.

Configuration & availability

Legacy or missing compiler declarations and potentially unbounded iteration.

PROVENANCE & REVIEW RECORD

Source	Filename and SHA-256 identify the analyzed source snapshot.
Run	Timestamp, source identity, prompt variant/version, execution limits and overall review status.
Models	Model identities, attempts, outcomes, timings and available token usage; failed-attempt usage may be unknown.

EXPORT FOR FOLLOW-UP

JSON	Static report, consolidated findings, validated model reviews and execution provenance.
Markdown	Readable findings, attempts, contribution details and an independent static baseline.

Review scope: one Solidity source file. Contracts are not compiled, imports are not resolved and exploits are not executed.

Bounded execution. Controlled evaluation.

Inspect operational reliability on the same five contracts before drawing conclusions about detection quality.

2 attempts

PER MODEL, MAXIMUM

One initial call plus one eligible transient retry.

180 seconds

PER MODEL, ABSOLUTE

210 seconds for the server run. Retry time is included.

30 calls

PER FIVE-CASE VARIANT, MAXIMUM

Five sequential analyses; at most six provider calls each.

CONTROLLED PROMPT COMPARISON

Standard prompt

Shared review instructions and output schema provide the baseline for all three models.

Guided examples

Separate synthetic examples illustrate grounded claims and benign lookalikes. No reference-case answers or peer findings are supplied.

FIVE-CASE VALIDATION

01 Fix the conditions

Choose one prompt variant. Keep the five source files and three model identities unchanged.

02 Run sequentially

Inspect progress or cancel. Completed case records remain available; no new cases start after cancellation.

03 Export and compare

Retain completion, attempts, latency, usage and differences. Start the other variant as a separate run.

A bounded retry addresses an eligible temporary error; it does not repair permissions or invalid evidence.

Compare execution outcomes first. Quality claims require human-reviewed findings; model agreement is not accuracy.

Cancellation cannot reverse work already accepted by AWS. Returned token totals may omit usage from failed attempts.

Connect, review and share from your browser.

Use a valid Amazon Bedrock key with access to the three configured models in US East (N. Virginia).

BROWSER WORKFLOW

01 Prepare your source

Open a reference case, upload one .sol file or edit the source directly.

02 Add your Bedrock key

Select API analysis, paste the complete key and choose Use API key. Adding it checks format; analysis verifies model access.

03 Run and inspect

Choose Run API analysis, then inspect all three model outcomes, consolidated findings and original contributions.

04 Export and clear

Download JSON or Markdown. Select Clear key or refresh the page to remove the active key from the tab.

INTERPRET MODEL COVERAGE

Completed	3 / 3 models returned validated reviews.
Partial	1 or 2 succeeded. Their reviews remain available; failures stay explicit.
Failed	No validated model review is available. The independent static baseline remains usable.

Your key stays in this tab's memory and in server-request memory. API analysis sends the source and key through the site's server to AWS; your account's permissions and usage charges apply.

A successful empty review, partial coverage or a completed run does not establish that a contract is safe.

OPEN THE PLATFORM

dtcc-multi-agent-audit.vercel.app

SOURCE & LOCAL SETUP

github.com/ChaoLabs/dtcc-multi-agent-audit

CONNECTION & ANALYSIS GUIDE

dtcc-multi-agent-audit.vercel.app/guide